CloudDesk Technologies

Human Resources Security Policy

1. Authority, scope and proposed status

SYNTHETIC / DEMO - document control

CD-HRS-001 | Version 1.0 | Fictional effective date: 2026-10-22 | Next review: 2027-10-22. CTO is accountable and approves adoption; Engineering Lead is security coordinator and policy owner. Review annually and after material personnel, service or incident changes. Editable UTF-8 JSON is the source for this PDF. Approval_status: not_recorded; review_status: requires_user_review.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored Policy 7 of an intended eight-policy collection contains proposed SYNTHETIC / DEMO requirements, not operating facts. No established HR department, completed screening, actual training, existing personnel data processing practices, certification or legal compliance conclusion is asserted. Human content review and recorded CTO approval are required before operational adoption.

Scope and responsibility

Cover employees, temporary personnel, contractors and vendor workforce with access to company systems or scoped information, from engagement through departure. Managers or designated personnel coordinators arrange engagement records, role changes and departure notices; no dedicated personnel team is assumed. System owners approve business access and authorized operators implement changes. Engineering Lead coordinates security checks, exceptions and evidence; CTO accepts material residual risk. Identify named substitutes and verified contact routes before adoption.

Related policy authority

Preserve all six related policies: access control governs identity, administrative MFA, quarterly reviews and termination revocation; encryption governs keys and data protection; information security governs risk and training; incident response governs urgent containment and evidence; backup/disaster recovery governs retained recovery dependencies; change management governs scoped technical changes. Record unresolved conflicts for Engineering Lead and CTO resolution before adoption. This personnel policy grants no new destructive, decrypt or external communication authority.

Human Resources Security Policy

2. Before engagement and confidentiality

Risk-appropriate preemployment screening

Before engagement, the manager or designated personnel coordinator proposes screening appropriate to role, access sensitivity and risk, with qualified jurisdiction-specific advice where needed. Establish lawful authority, required consent, permitted sources, proportionality and handling before any check. There is no universal background-check requirement and no fixed screening frequency. If a check is restricted or unsuitable, document the limitation and proposed safeguards for CTO risk review; do not assume consent makes every check lawful.

Screening decisions and records

Use authorized reviewers and relevant, verified information; give appropriate opportunity to address disputed findings under applicable processes. Record scope, authority, decision and access conditions with minimal personal information rather than distributing raw reports. Set approved retention before collection. Do not infer fitness from unsupported allegations or sensitive characteristics. This sample records no completed screening or hiring decision and makes no employment law determination.

Confidentiality and acceptable use

Before granting access, arrange appropriate confidentiality/NDAs and acceptable-use acknowledgments under reviewed agreements. Explain classification, approved sharing, credential protection, phishing, secure devices, reporting and continuing confidentiality after departure as applicable to the agreement. Prohibit credential sharing, unauthorized exports, personal storage of company information and use of secrets in code or support logs. No signed agreement or actual acknowledgment is supplied.

Contractor and vendor workforce

The engagement owner defines sponsor, scope, start/end dates, confidentiality, security responsibilities, incident reporting, access termination and information return/deletion terms before access. Assess vendor workforce assurance proportionately with Engineering Lead review and CTO acceptance of material residual risk. Do not assume vendor certification or identical employment screening rules. Use named identities, approved access and expiry conditions; verify sponsor and contract changes. Reassess critical vendors annually and after material changes or incidents under information security governance.

Human Resources Security Policy

3. Onboarding, identity and learning

Onboarding approvals and provisioned identity

The manager requests access with confirmed identity, role, start date, sponsor and required systems; system owners approve least privilege before authorized operators provision identity. Use unique user accounts and multi-factor authentication for administrative access. Record requester, approver, provisioning actor, permissions and completion time. Do not copy a predecessor account or grant blanket access from a job title. Coordinate changes affecting production through change management; Engineering Lead checks missing approvals and unresolved risk before access is enabled.

Least privilege and privileged role preparation

Limit access to approved duties and time needed; separate privileged and ordinary work where supported. Before privileged duties, arrange role-specific training on approved administration, secret handling, change approvals, incident escalation and evidence preservation. Engineering Lead approves key grants under the encryption policy; key administrators have no default decrypt permission. Any missing prerequisite requires documented risk assessment and approved bounded safeguards, never silent self-approval.

Proposed onboarding and annual security awareness

Managers arrange security awareness at onboarding and annually thereafter, including phishing, credential protection, classification, acceptable use, safe sharing, personal information protection and incident reporting. Provide additional guidance when roles, threats or systems change. Make material accessible to the assigned audience and record overdue follow-up with the manager. These are proposed activities; no actual training delivery, completion rate or tested competence is claimed.

Training records and access readiness

Engineering Lead tracks assigned modules, role, due date, attendance/completion, assessment where appropriate, acknowledgment and follow-up owner. Managers resolve overdue assignments and assess temporary restrictions with system owners based on risk. Preserve exceptions and approval evidence without inventing universal training deadlines or automatic sanctions. Maintain access-readiness and equipment handover checklists as proposed evidence, not completed records.

Human Resources Security Policy

4. Transfers, leave and offboarding

Transfers, leave and role changes

Managers or personnel coordinators promptly notify system owners and Engineering Lead of transfers, leave, changed duties and return dates through verified routes. Adjust least privilege in a timely manner aligned to the effective change and risk; remove obsolete permissions rather than merely adding new ones. Assess temporary suspension during leave, reassess on return and record approval before reactivation. Preserve necessary business records and approved holds; a leave event does not itself establish misconduct.

Periodic access review every quarter

Review user access permissions every quarter, including privileged roles, dormant accounts, contractor end dates and sponsor validity. Managers confirm current duties; system owners validate entitlements; Engineering Lead tracks removal and unresolved findings. Reconcile identity and personnel change records, document reviewers, decisions and verification times, and escalate overdue material risk to CTO. These proposed reviews are not claimed completed and do not replace event-driven access adjustments.

Termination linkage and immediate containment

Under the original access_control_policy.pdf, revoke terminated employee access within 24 hours of termination. Treat this as an outer limit, not a waiting period: plan revocation at the effective departure time when practicable. Urgent compromise requires immediate containment under incident_response_plan.pdf; do not delay containment for the 24-hour window, a ticket or routine personnel approval. Responders may take urgent reversible action under incident authority; CTO retains material shutdown and residual-risk decisions. Apply coordinated timely removal to contractor/vendor departures with recorded scope and verified completion.

Offboarding checklist, assets and preservation

Managers coordinate verified departure notice and asset return; system owners and authorized operators disable accounts, revoke sessions, tokens, remote access and delegated grants, remove groups and rotate shared secrets where exposure requires. Record exceptions, outstanding assets and verified revocation times. Transfer ownership of necessary records and service dependencies without sharing credentials. Preserve incident/evidence holds and relevant logs before disposal where safe; do not delay urgent containment to collect evidence. Returning a device alone does not revoke access. Preserve retained backups and required key versions under recovery policies; departure does not authorize key destruction.

Human Resources Security Policy

5. Personal information, reports and investigations

Personal information protection and approved retention

Limit proposed personnel information collection to a specified necessary purpose with appropriate authority, transparency and consent where required. Restrict access to authorized need-to-know roles, protect storage and transfers using the encryption policy, and document recipients and safeguards before use. Actual processing locations, processors and personnel datasets are not asserted. Retention remains TBD pending applicable laws/contracts and approved business needs; obtain appropriate advice and record an approved schedule and holds before collection or disposal. No universal personnel retention period is set.

Reporting and proportionate response

Personnel promptly report suspected misuse, lost assets, phishing, exposure or policy violations to Engineering Lead through proposed verified internal routes; contact CTO or a designated alternate if unavailable or implicated. No live reporting service or guaranteed staffing is claimed. Limit sensitive details and do not include credentials. Managers and CTO assess proportionate corrective or disciplinary action under applicable agreements and processes with appropriate advice. There is no automatic sanction or predetermined employment outcome; support good-faith reporting and avoid retaliation.

Insider-threat investigation privacy protections

Investigate credible concerns under documented authority, defined scope and proportionate collection; separate facts from hypotheses. CTO assigns an impartial authorized investigator or alternate when a conflict exists, with qualified privacy/legal advice as needed. Limit access to necessary evidence, protect confidentiality and fair opportunity to address findings under applicable processes. No blanket employee surveillance, unrestricted access to private accounts or presumption of guilt is authorized. Escalate suspected incidents through incident response rather than conducting informal searches.

Evidence integrity and hold decisions

Use incident IDs, custodians, collection provenance, integrity hashes where appropriate, access logs and chain-of-custody transfers under the incident response plan. Preserve originals and analyze controlled copies; document uncertainty and unavailable records. Coordinate incident/evidence holds with authorized decision makers and advice, suspending routine disposal where required. Retain only justified information and review access and hold scope. The encryption policy minimum 12-month retention for KMS audit logs only is not a personnel-record retention rule. No actual investigation or evidence collection is claimed.

Human Resources Security Policy

6. Exceptions, evidence and annual review

Bounded exceptions and emergency deviations

Before a planned deviation, the responsible manager or owner records requirement, scope, reason, risk, compensating safeguards, remediation owner and expiry. Engineering Lead assesses; CTO approves or rejects. Approved exceptions expire within 90 days and are reviewed monthly; renewal requires fresh assessment and approval. Expired approval cannot authorize access. Emergency deviations require an incident record and next-business-day CTO review; do not delay urgent containment. An exception cannot authorize unlawful screening, erase applicable obligations or silently extend the original 24-hour termination requirement. No active exception is asserted.

Proposed evidence types

Expected evidence includes role risk assessments, screening authority/consent decisions where applicable, confidentiality and acceptable-use acknowledgments, onboarding access approvals, identity/MFA checks, training assignments/completion and follow-up, transfer/leave tickets, quarterly reviews, offboarding revocation timestamps and asset returns. Also retain contractor sponsor/end-date reviews, authorized investigation records, retention/hold decisions, exceptions and policy review feedback. These are proposed evidence types, not actual personnel files or operating-control evidence; minimize sensitive contents and assign restricted custodians.

Governance review and dependencies

Engineering Lead checks personnel-security gaps and corrective actions with managers and system owners, escalating material residual risk to CTO. Review this policy at least annually and after significant incidents or material role, vendor or service changes. Preserve encryption approvals and recovery holds; scoped technical changes follow CD-CHG-001. Reconcile training with onboarding and annual awareness in CD-ISP-001, and access reviews with the original quarterly requirement. No new screening cadence, retention number or recovery target is introduced.

Human adoption gate

Human reviewers must validate jurisdiction/consent constraints, contracts, practical personnel coordination and substitutes, reporting routes, proportionate investigations, training plans, retention schedules and all six related policies. Record conflicts, reviewer feedback and CTO approval before adoption. Approval_status: not_recorded; review_status: requires_user_review. Passing extraction, deterministic rebuild and lexical retrieval tests does not establish human semantic approval, actual practices, employment law compliance or operating effectiveness.